

SECURITY ADVISORY

API SECURITY RISK ANALYSIS REPORT

Jebin A

Cyber Security Intern Future Interns

April 2026

01. Executive Summary

In an era of hyper-connectivity, APIs are the primary gateway to organizational data. This assessment focuses on identifying security architectural flaws and configuration weaknesses within the provided scope.

The audit identified **6 key findings** ranging from **High** to **Medium** severity. The primary concerns involve the lack of robust authentication and excessive data exposure of PII (Personally Identifiable Information). Immediate remediation of High-severity findings is recommended to prevent unauthorized data access and potential regulatory non-compliance.

02. Introduction & Objective

THE IMPORTANCE OF API SECURITY

APIs are often the weakest link in the modern application stack. Unlike traditional web interfaces, APIs provide direct access to data structures, making them susceptible to mass assignment and broken object-level authorization (BOLA) if not properly secured.

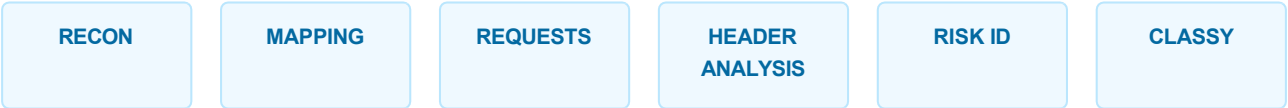
CORE OBJECTIVES

- Verify endpoint security and authentication protocols.
- Evaluate data exposure risks and payload sensitivity.
- Assess the effectiveness of existing rate-limiting and security headers.
- Provide a roadmap for technical remediation.

03. Assessment Scope

CATEGORY	DETAIL
Target Host	https://jsonplaceholder.typicode.com
Analysis Type	External Black-box Security Audit
Tools Utilized	Postman
Testing Methodology	Read-Only / Non-Destructive

04. Methodology



The assessment followed a standardized security lifecycle: initial reconnaissance to identify endpoints, followed by manual request manipulation to observe server responses. Each finding was then cross-referenced with the **OWASP API Security Top 10** to determine severity and impact.

05. Findings & Risk Analysis

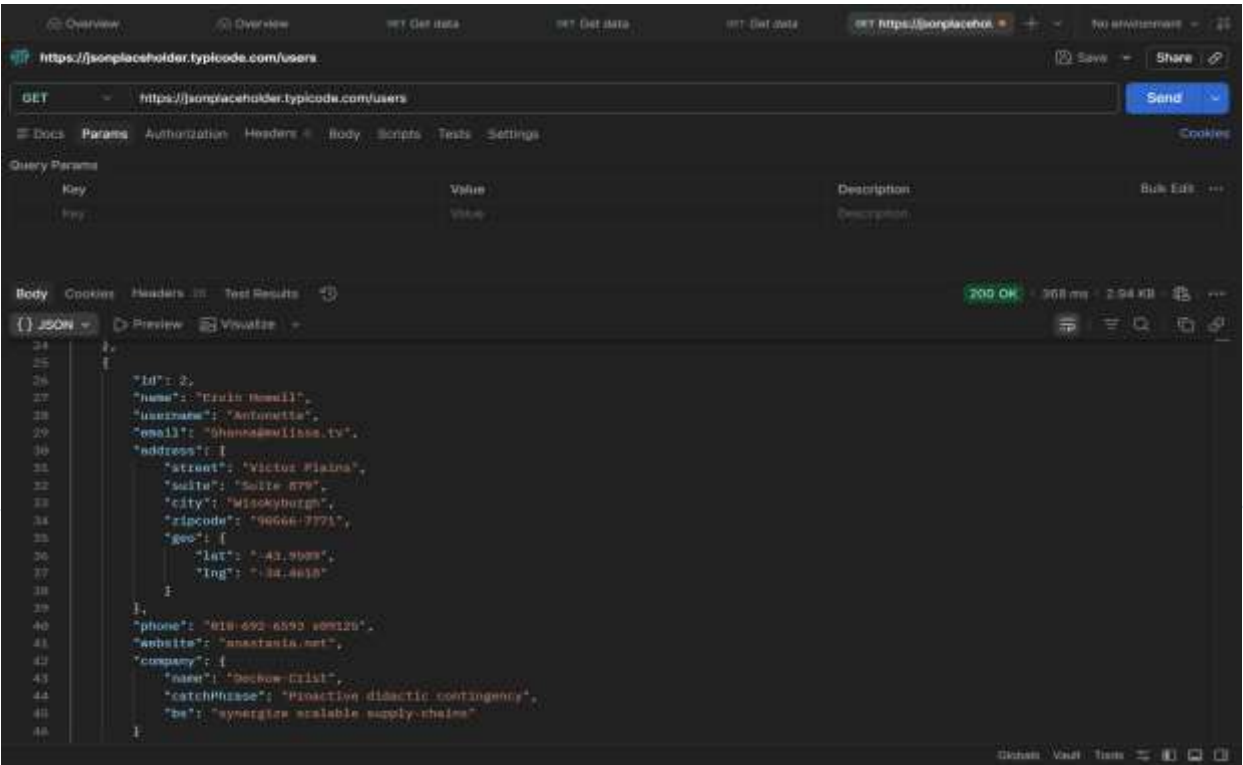
Finding 01: Open API Endpoint

HIGH SEVERITY

Description: Critical endpoints are accessible without any authentication tokens (JWT, OAuth, or API Keys).

Business Impact: Risk of automated data scraping and exposure of internal user databases to unauthorized actors.

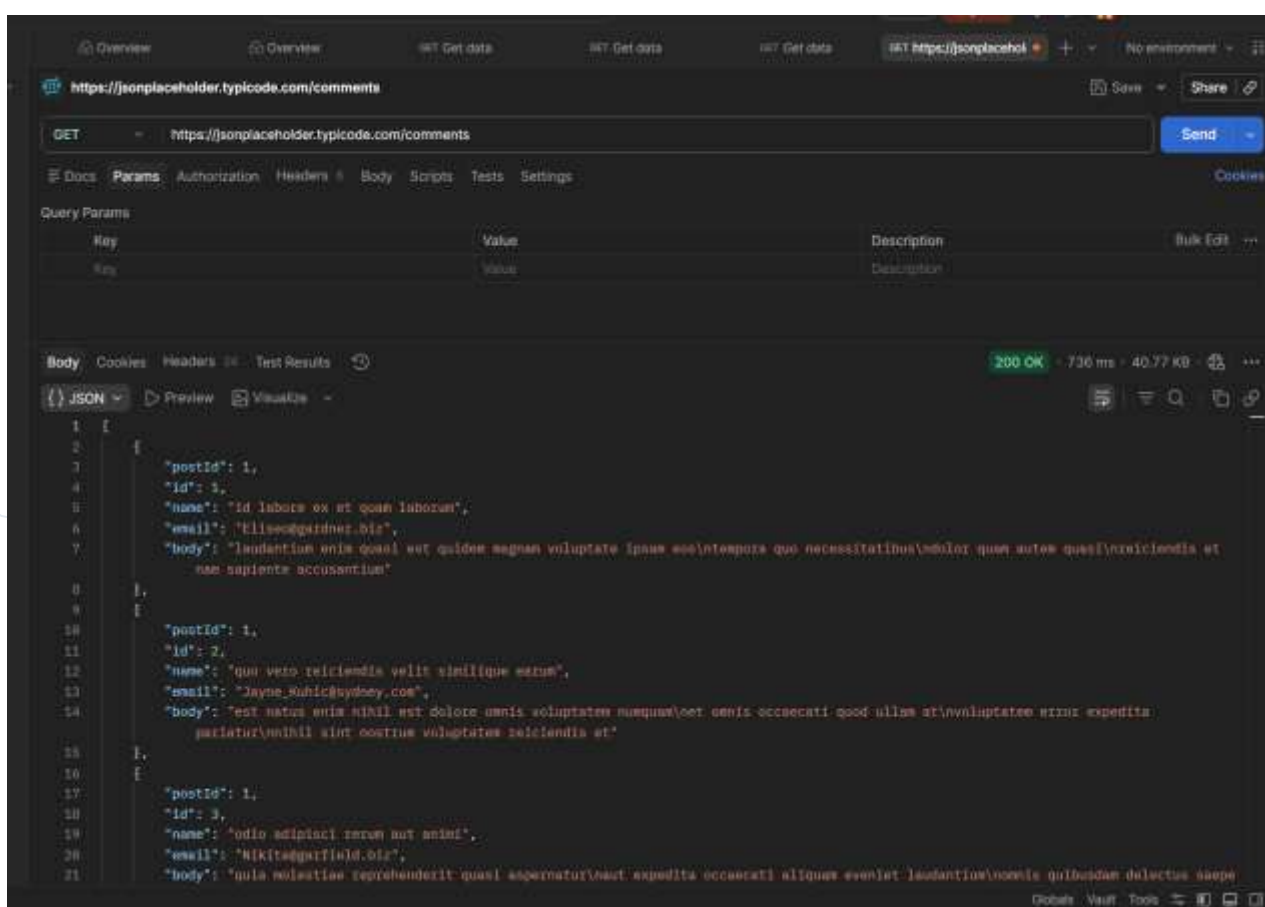
Remediation: Implement a Zero-Trust architecture requiring valid Bearer tokens for all data-retrieval endpoints.



HIGH SEVERITY

Business Impact: High risk of GDPR/CCPA compliance violations due to unnecessary data transmission.

Remediation: Implement response filtering at the controller level to return only public-facing fields.

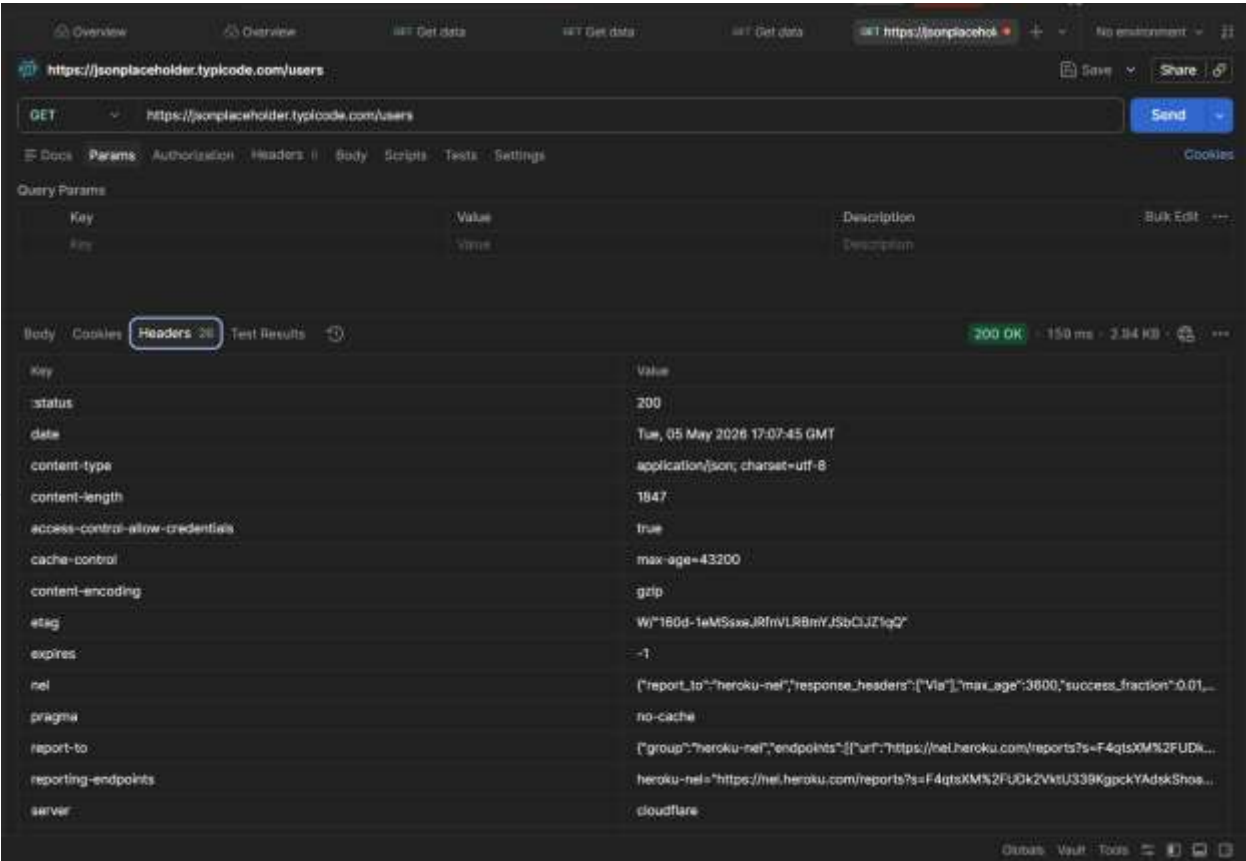


Finding 03: Missing Security Headers

MEDIUM SEVERITY

Description: Responses lack essential security directives like HSTS, CSP, and X-Content-Type-Options.

Business Impact: Facilitates client-side attacks and protocol downgrade vulnerabilities.



06. Risk Summary Table

VULNERABILITY	SEVERITY	IMPACT CATEGORY
Open API Endpoint	HIGH	Data Confidentiality
Excessive Data Exposure	HIGH	Compliance / Privacy
No Authentication Mechanism	HIGH	Access Control
Unrestricted Data Access	MEDIUM	Resource Exhaustion
No Rate Limiting	MEDIUM	Service Availability
Missing Security Headers	MEDIUM	Defensive Posture

07. Recommendations & Conclusion

- **Auth Implementation:** Deploy OAuth 2.0 / OpenID Connect immediately.
- **Data Minimization:** Review all API schemas to prune unnecessary fields.
- **Throttling:** Apply a global rate limit of 100 req/min per IP.
- **Security Headers:** Update web server configuration for all production environments.

In conclusion, while the API is functional, the lack of fundamental security controls presents a high risk to the organization. Adopting the recommendations above will significantly harden the infrastructure against modern web threats.